

Risk Management Policy

Version: v1.0 ADOPTED **Adopted:** 2026-07-21 by Sami Ben Chaalia (Security Officer) **Date:** 2026-07-21 **Owner:** Security Officer (Sami Ben Chaalia) **Framework mapping:** SOC 2 CC3.1–3.4 (Risk assessment) · HIPAA §164.308(a)(1)(ii)(A/B) (Risk analysis + risk management) · ISO 27001 clause 6.1 · NIST SP 800-30r1 (Risk assessment) **Companion documents:** HIPAA SRA v1 (compliance/HIPAA_SRA_v1_2026-07-21.md) · Incident Response Policy §3 (severity classes) · every other policy in Probo (each closes a specific risk).

1. Purpose

Turn the point-in-time SRA into an operating risk register that gets used, not filed. Every risk here has a named owner, a treatment strategy, and a review date — so decisions about tradeoffs are made deliberately, not accidentally by omission.

2. Scope

- Every risk identified in the SRA (§3.1–3.8 of `HIPAA_SRA_v1_2026-07-21.md`).
- Every gap listed as `GAP` or `PARTIAL` in SRA §4.
- Every accepted operational limit documented in this policy set (Encryption §5, BC/DR §5.5, Vendor Mgmt §3.1).
- New risks discovered during incidents (per Incident Response Policy §9 post-mortems).

3. Risk-scoring model

Two numbers per risk. Both on a 1–5 scale, both deliberately coarse — a two-person team can't defend fine gradations honestly.

Likelihood — how probable is realization within the next 12 months: - 1 Rare (requires unusual conditions we don't foresee) - 2 Unlikely (possible but no known driver) - 3 Possible (a known driver exists but no active pressure) - 4 Likely (active pressure or known-vulnerable path) - 5 Almost certain (already happened, or actively being tried)

Impact — if realized, blast radius: - 1 Negligible (< 1 h of ops noise) - 2 Minor (one customer affected, contained) - 3 Moderate (multiple customers or one enterprise, no data loss) - 4 Major (data loss, regulatory notification, revenue hit) - 5 Severe (existential — brand-eroding breach, trust root compromise)

Score = Likelihood × Impact. 1–25.

Bands: - 15–25 = **HIGH** — treat within 30 days OR document explicit acceptance with sign-off - 8–14 = **MEDIUM** — treat within 90 days OR accept with review at next quarter - 1–7 = **LOW** — track, review annually

4. Treatment strategies

Named per NIST/ISO conventions. Every risk in §6 chooses one:

- **MITIGATE** — reduce likelihood and/or impact via a control. Requires an owner + a target date. This is what most P0 remediations did.
- **ACCEPT** — acknowledge and continue as-is because mitigation cost exceeds expected loss OR mitigation would break another property (e.g., unattended operation). Requires an owner + a review date.
- **AVOID** — remove the source of the risk. Example: not accepting PHI on the gateway (§164.312 transmission gap was AVOIDED by never accepting bodies).
- **TRANSFER** — shift the risk to a third party via contract or insurance. Example: relying on Stripe's PCI-DSS Level 1 posture for card handling.

5. Ownership

Every risk has ONE owner. Currently every entry defaults to Sami (Security Officer). When headcount grows, ownership should be distributed — the Owner column here is the enforcement mechanism for that transition.

6. Risk register — v1 baseline

Structured so it can be imported into Probo's risk module as `addRisk` entries. Same numbering as SRA §3 so cross-reference is trivial.

R-01 — Local file-system exposure of signing seed (SRA §3.1)

- **Likelihood:** 2 (backup/sync exposure was a real driver pre-P0-1)
- **Impact:** 5 (receipt trust root compromised → every receipt from that install becomes suspect)
- **Score:** 10 MEDIUM
- **Treatment:** MITIGATED (P0-1 closed 2026-07-20 for station, 2026-07-21 for CLI)
- **Residual:** same-user malware can still reach keychain. LOW residual score (Likelihood 2 × Impact 3 = 6). ACCEPTED with review at annual SRA refresh.
- **Owner:** Sami

- **Evidence:** Probo measure `P0-1` ; Encryption Policy §4.1; test_seed_store.py 16/16.

R-02 — Audit log tamper (SRA §3.2)

- **Likelihood:** 2
- **Impact:** 4 (§164.308(a)(1)(ii)(D) audit requirement met in name but not substance)
- **Score:** 8 MEDIUM
- **Treatment:** MITIGATED (P0-2 closed via `audit_chain`)
- **Residual:** tail-truncation by install-key holder undetectable. Impact 4 unchanged (still §164.308 gap for that case) but Likelihood drops to 1 (requires local root access already). Score 4 LOW. ACCEPTED pending off-box witness on the roadmap.
- **Owner:** Sami
- **Evidence:** Probo measure `P0-2` ; audit_chain.py + test_audit_chain.py 17/17.

R-03 — PHI egress via generic-named fields (SRA §3.3)

- **Likelihood:** 4 (customers with clinical data + generic field names is exactly the shape a healthcare deployment takes)
- **Impact:** 5 (SSN survived redaction pre-P0-3 — worst-case egress path)
- **Score:** 20 HIGH → post-remediation revisit
- **Treatment:** MITIGATED (P0-3 closed via `phi_guard` + auto-escalation + install-level PHI mode)
- **Residual:** personal names in free text still not detectable; escalation is opt-in per install. Likelihood drops to 2 (only realized if PHI mode is NOT enabled AND field names are all generic AND names appear in free text). Impact still 4 (single-record). Score 8 MEDIUM. ACCEPTED with mandatory operator notice at BAA-signature time (installer must set `RAILCALL_PHI_MODE=on` before touching PHI).
- **Owner:** Sami
- **Evidence:** Probo measure `P0-3` ; phi_guard.py + test_phi_guard.py 29/29.

R-04 — Plaintext PII in audit records (SRA §3.4)

- **Likelihood:** 4 (already realized in 2 of 49 real records)
- **Impact:** 2 (email is identifying but not clinical)
- **Score:** 8 MEDIUM
- **Treatment:** MITIGATED (P0-4 closed same commit as P0-2)
- **Residual:** any new "sensitive-shaped" field name added to the code path could regress. Score 2 LOW.

- **Owner:** Sami
- **Evidence:** Probo measure `P0-4`.

R-05 — Cross-install entitlement replay (SRA §3.7)

- **Likelihood:** 3 (natural human behavior — "I paid, why can't I use it on my second machine?")
- **Impact:** 3 (revenue leak proportional to how much replay happens)
- **Score:** 9 MEDIUM
- **Treatment:** MITIGATED
- **Residual:** LOW (Likelihood 1 × Impact 3 = 3). Entitlements are bound to `install_pubkey`; seat cap enforced server-side; TTL-based prune keeps the accounting live.
- **Owner:** Sami
- **Evidence:** entitlement.py `verify_entitlement`; `/v1/seat/checkin` in cloud_gateway.py; test_activate_e2e.py step 3a; test_paid_full_e2e.py E1-E4.

R-06 — Studio approval token compromise (SRA §3.8)

- **Likelihood:** 2 (requires a compromised browser process on the customer's box)
- **Impact:** 4 (a self-approved external send bypasses dual control)
- **Score:** 8 MEDIUM
- **Treatment:** MITIGATED (approve token printed to terminal only, never templated into any served page)
- **Residual:** LOW (Likelihood 1 × Impact 4 = 4). ACCEPTED — an already-compromised browser has bigger problems than an unlocked studio.
- **Owner:** Sami

R-07 — Paid-tier billing integrity on cancel (SRA §3.6)

- **Likelihood:** 3 (customers cancel — it's normal)
- **Impact:** 2 (cancelled customer keeps consuming seats they don't pay for)
- **Score:** 6 LOW pre-treatment
- **Treatment:** MITIGATED (Stripe `customer.subscription.deleted` + `.updated` webhook branch flips `status=inactive`, `seat_count=0`)
- **Residual:** MINIMAL. Score 2 LOW.
- **Owner:** Sami
- **Evidence:** cloud_gateway.py lifecycle handler; test_stripe_lifecycle.py 11/11.

R-08 — Contract-violation PHI on `/v1/attestation/countersign` (SRA §5.3)

- **Likelihood:** 2 (requires deliberate protocol violation by caller)
- **Impact:** 3
- **Score:** 6 LOW
- **Treatment:** MITIGATED by explicit param typing (endpoint has no body field). ACCEPTED — a future edit could regress this; process control is code review.
- **Owner:** Sami

R-09 — Same-user malware defeats keychain (SRA §5.1 / Encryption §7)

- **Likelihood:** 2 (customer's box malware is not our attack surface, but it's a real environment risk)
- **Impact:** 5 (signing seed compromise per-install)
- **Score:** 10 MEDIUM
- **Treatment:** ACCEPTED — mitigation (hardware token / per-signature passphrase) breaks unattended operation, which is the point of a local automation engine.
- **Owner:** Sami (documented + surfaced via `railcall doctor`)
- **Review:** annually — if hardware tokens become ubiquitous enough to enable optionally, re-open.

R-10 — Audit-chain tail truncation (SRA §5.2)

- **Likelihood:** 2 (requires install-key holder acting against their own compliance interest)
- **Impact:** 3 (post-incident evidence weakened)
- **Score:** 6 LOW
- **Treatment:** ACCEPTED pending off-box witness. Test 4a asserts the limit publicly so no auditor is misled.
- **Owner:** Sami
- **Target:** Off-box witness on roadmap; not-committed date.

R-11 — Issuer seed loss (BC/DR §5.1)

- **Likelihood:** 1 (backup exists in 1Password + paper)
- **Impact:** 5 (existential — every outstanding entitlement becomes unreplaceable)
- **Score:** 5 LOW
- **Treatment:** MITIGATED via backup redundancy; runbook proven in BC/DR §5.1.
- **Owner:** Sami

R-12 — Third-party outage (BC/DR §5.2, §5.5, §5.6)

- **Likelihood:** 4 (SaaS outages happen)
- **Impact:** 2 (bounded by vendor SLA + our RTO)
- **Score:** 8 MEDIUM
- **Treatment:** ACCEPTED. TRANSFERRED to vendor SLAs (Render, Stripe, GitHub). Free-tier installs unaffected by design.
- **Owner:** Sami
- **Review:** on any vendor SLA change.

R-13 — Sami unavailable (BC/DR §5.7)

- **Likelihood:** 3 (happens — vacation, illness, travel)
- **Impact:** 3 (velocity slows; SEV-1 response degraded)
- **Score:** 9 MEDIUM
- **Treatment:** PARTIALLY MITIGATED — Pat has SSH + Render + Stripe admin. Sealed physical backup of issuer seed is an OPEN action item; Pat-usable Anthropic API key is an OPEN action item.
- **Owner:** Sami
- **Target date for open items:** end Q3 2026.

R-14 — Sami laptop lost/stolen (BC/DR §5.8)

- **Likelihood:** 2
- **Impact:** 4 (short window of exposure until rotation)
- **Score:** 8 MEDIUM
- **Treatment:** MITIGATED via runbook (§5.8). 1Password E2E encryption is the primary control; issuer seed paper backup is the ultimate fallback.
- **Owner:** Sami

R-15 — Overclaim on compliance page (regulatory + reputational)

- **Likelihood:** 5 (already realized pre-2026-07-21 — /enterprise carried "HIPAA BAA available" and "SOC 2 in progress" without evidence)
- **Impact:** 4 (misleading advertising is enforceable by state AGs + destroys enterprise-buyer trust when caught)
- **Score:** 20 HIGH → post-remediation revisit

- **Treatment:** MITIGATED (softened /enterprise language in `9696012`; SRA + policies now provide the evidence base honestly).
- **Residual:** LOW (Likelihood 1 × Impact 4 = 4) — process control is the "no fake-green" rule (see `feedback_railcall_culture.md`).
- **Owner:** Sami

R-16 — Multi-user host deployment without §164.312(d) human auth

- **Likelihood:** 2 (specifically healthcare — the customer class most likely to run on shared hosts)
- **Impact:** 3
- **Score:** 6 LOW
- **Treatment:** ACCEPTED — customer's own OS user boundary is the compensating control. Multi-user hardening on product roadmap; when it lands, R-16 revisits.
- **Owner:** Sami

7. Register maintenance

- **Adding a risk:** on discovery (incident, code review, external report). Fill all fields; missing owner = policy violation.
- **Updating a score:** when new evidence changes Likelihood or Impact. Log the reason in the register history.
- **Closing a risk:** when treatment lands + verification confirms residual ≤ LOW. Move to §8 archive with the closing evidence.
- **Reviewing accepted risks:** at least annually, or on any change to the accepting context.

8. Quarterly review

Every quarter, this policy owner walks §6 and:

1. Confirms every MITIGATED entry's evidence still holds (test suites still green; files still exist; commits still reachable).
2. Confirms every ACCEPTED entry's accepting rationale still holds.
3. Confirms every OPEN action item has moved (or is escalated).
4. Adds any risks discovered in incidents that quarter.
5. Removes any risks made obsolete by architectural change (documented, not silently deleted).

Log the review as an incident-note-style artifact in `~/reviews/YYYY-QN-risk-review.md`. Reviewer signs at the bottom.

9. Related documents

- **HIPAA SRA v1** — the source material for §6 rows R-01 through R-08.
- **Incident Response Policy §9** — post-mortems that spawn new risks feed into §7.
- **BC/DR Policy §7** — the business impact analysis that calibrates Impact scores.
- **Encryption + Access Control + Vendor Mgmt + Change Mgmt Policies** — each closes a specific R-nn or documents an ACCEPTED one.